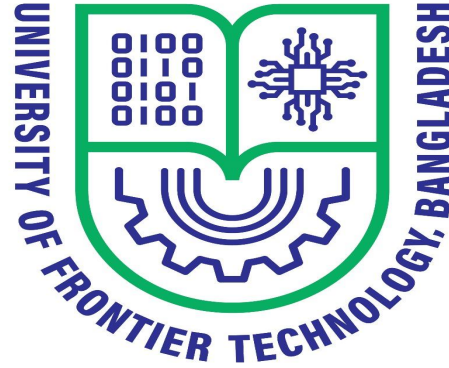


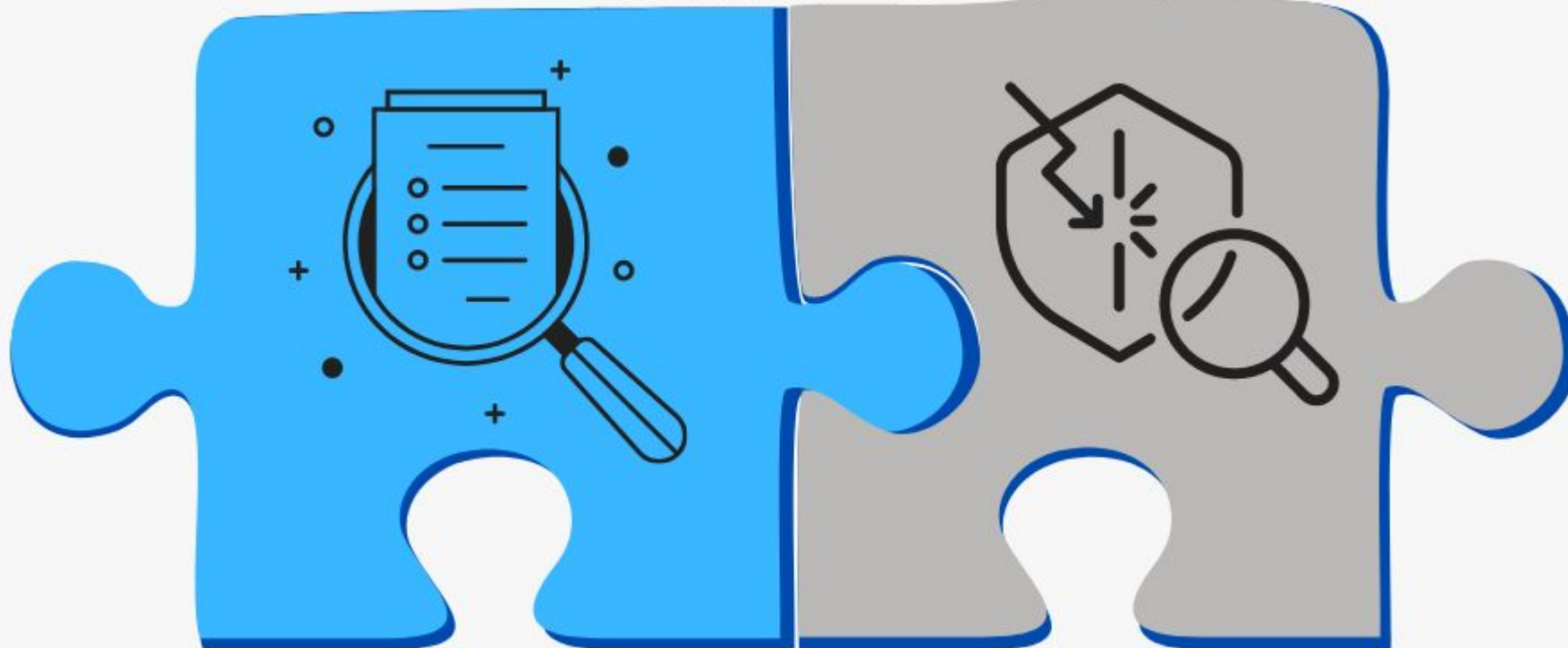


Vulnerability Assessment and Penetration Testing

Presented By:

Rakib Hossen
Assistant Professor
Dept. of Cyber Security Engineering (CySE), UFTB

VAPT



**VULNERABILITY
ASSESSMENT**

**PENETRATION
TESTING**

Vulnerability assessment and Penetration testing

Vulnerability Assessment and Penetration Testing (VAPT) is a systematic approach to **identify security weaknesses** and simulate attacks on a system to **evaluate its resilience against cyber threats**.



1. Vulnerability Assessment(VA)

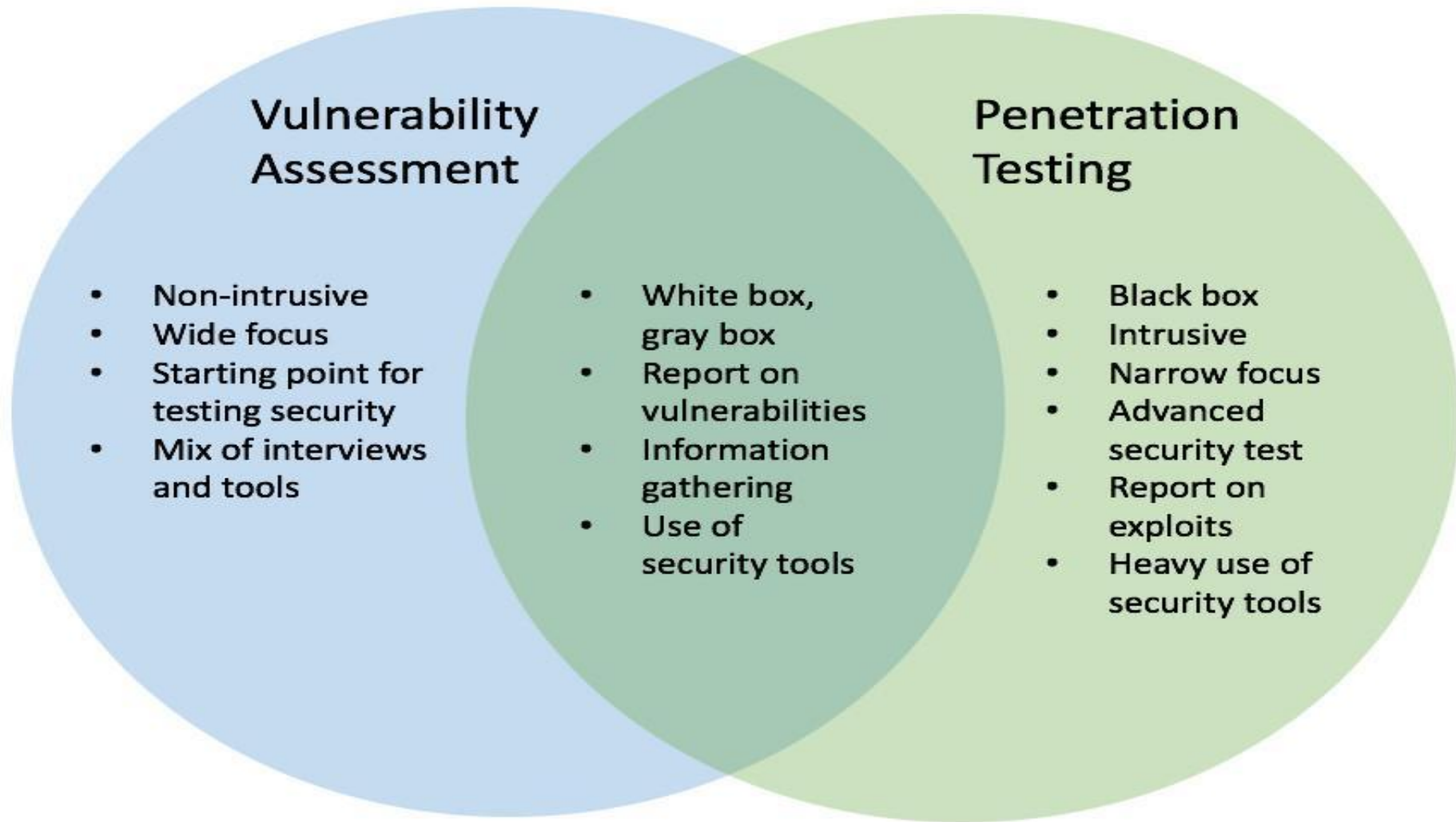
- Finds and identifies vulnerabilities
- Uses automated scanning
- Focus: What is wrong?



2. Penetration Testing (PT)

- Simulates real cyber attacks
- Uses manual & automated tools

Vulnerability assessment and penetration testing



Vulnerability

Assessment(VA)

A vulnerability assessment is a systematic process for identifying and evaluating vulnerabilities within an environment. The goal of a vulnerability assessment is to **discover weaknesses in your organization's infrastructure** that cybercriminals could potentially exploit.

Process of a vulnerability assessment

- ❖ **Discovery:** Scanning the entire environment **to identify all assets and systems.**
- ❖ **Scanning:** Automated tools **scan environment for known vulnerabilities,** misconfigurations, missing patches
- ❖ **Classification:** Identified vulnerabilities are **categorized based on severity** (critical, high, medium, low).
- ❖ **Reporting:** **Vulnerabilities are documented,** including descriptions, severity ratings and suggested remediations.

Process of a vulnerability assessment



Types of Vulnerability Scanning



Network-Based Scans

Identifies possible network security attacks and vulnerable systems on networks



Host-Based Scans

Finds vulnerabilities in workstations, servers, or other network hosts, and provides visibility into configuration settings and patch history



Wireless Scans

Identifies rogue access points and validate that a company's network is securely configured



Application Scans

Detects known software vulnerabilities and mis-configurations in network or web apps

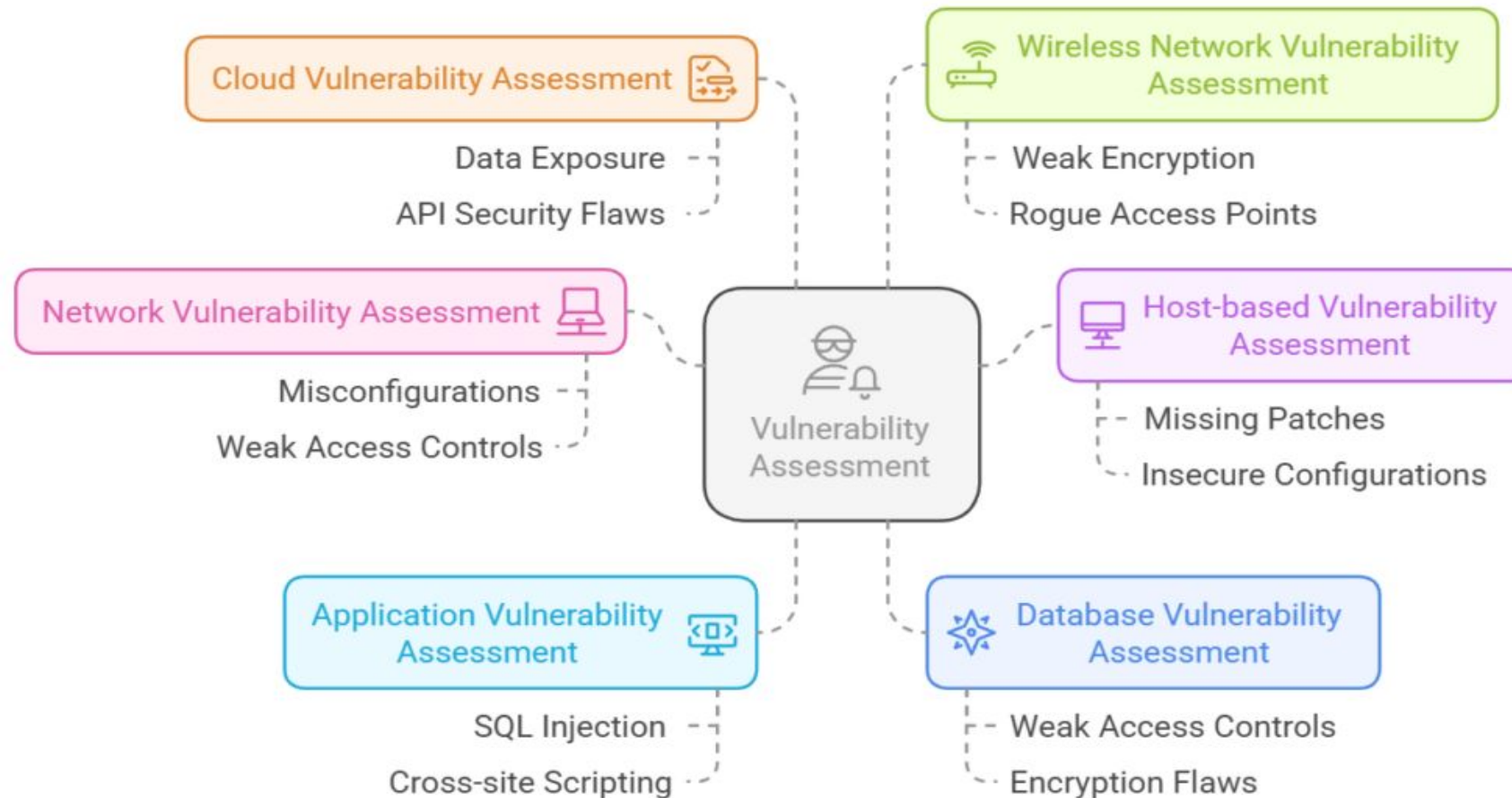


Database Scans

Identifies the weak points in a database

Types of Vulnerability Assessments

The most common types of vulnerability assessments



Network-based Scan

Identifies vulnerable systems on organizations wired and wireless networks, which could be used **to launch security attacks against an organization's networks.**



Example:

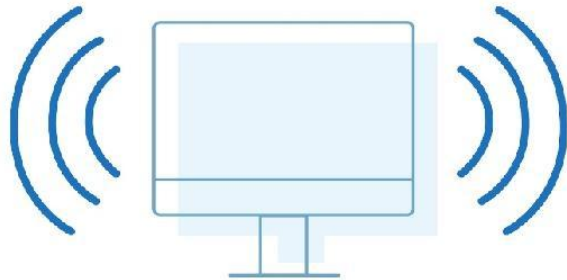
A company scans its internal network and finds open ports (e.g., port 22 for SSH) that are exposed to the internet, which attackers could exploit.

Network-based Scan

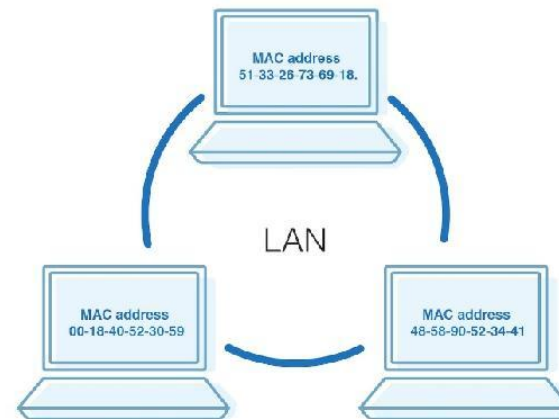
How Does a Network Scan Work?

A Network Scan:

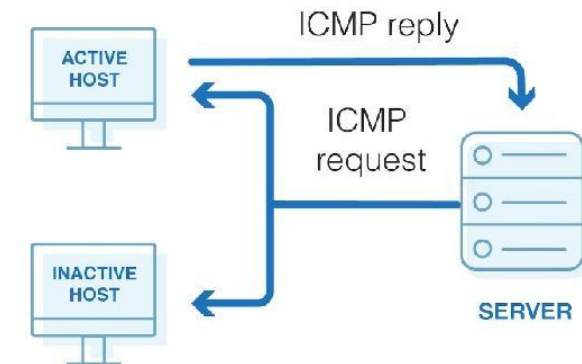
- 1 Discovers active hosts on the network



- 2 Uses Address Resolution Protocol (ARP) at the subnet level

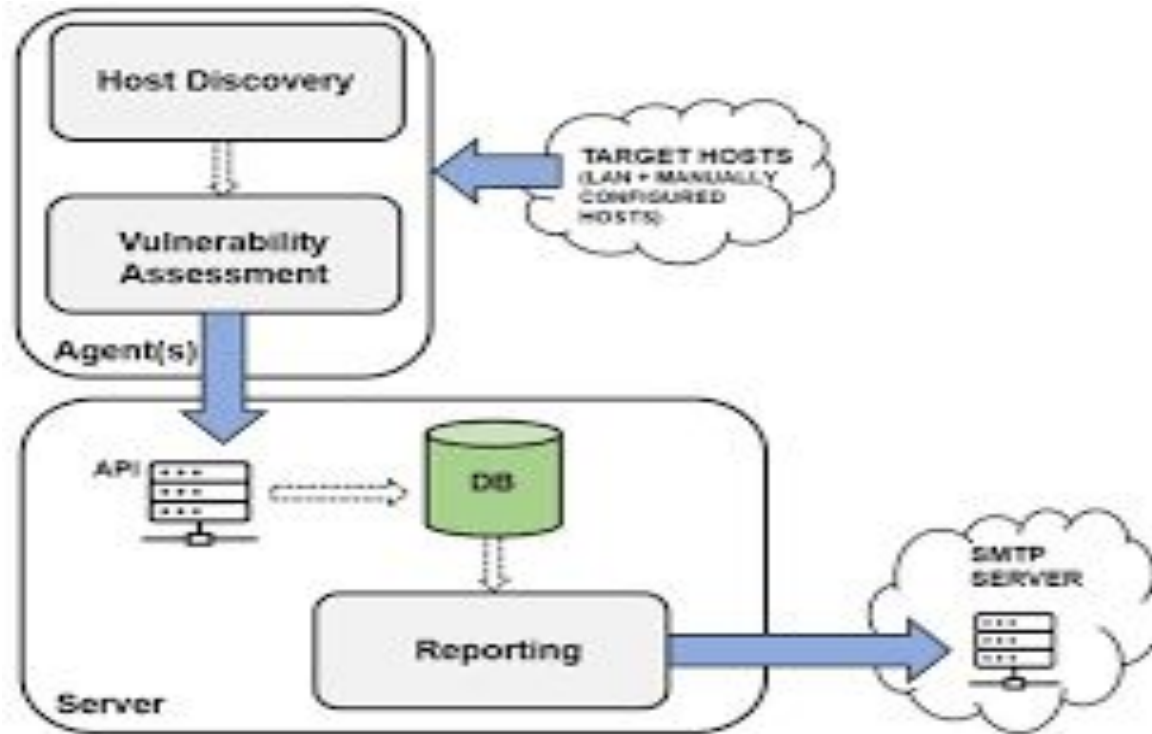


- 3 Or uses Internet Control Message Protocol (ICMP) for a wider reach



Host-based scan

Identifies potential vulnerabilities in hosts connecting to an organization's network, such as critical servers and workstations. This vulnerability assessment also provides further visibility into configuration settings and the system's patch history.



Example:

A scan detects that a Windows server is missing critical security patches, making it vulnerable to known exploits like ransomware attacks.

Wireless Scan

Typically assesses an organization's Wi-Fi connections to search for potential rogue access points (APs) and validate whether the network is configured securely.



Example:

The scan finds a rogue Wi-Fi access point installed by an employee or detects that the company Wi-Fi is using weak encryption (WEP instead of WPA2/WPA3).

Application Scan

Tests an organization's websites to search for known software vulnerabilities and weak configurations in web applications or networks.



Example:

A scan discovers a SQL Injection vulnerability in a login form, allowing attackers to access the database without proper authentication.

Database Scan

Identifies weaknesses in databases and big data systems, such as misconfigurations, rogue databases, or insecure development environments, to protect organizations against potential malicious attacks.



Example:

The scan reveals a database with default credentials (admin/admin) or misconfigured permissions, allowing unauthorized users to access sensitive data.

Vulnerability assessment: Security scanning process

The security scanning process consists of four steps: testing, analysis, assessment and remediation.



Vulnerability identification (testing)

Testing is the process of scanning systems, networks, or applications using automated tools to identify potential vulnerabilities.

- Tools scan for open ports, outdated software, weak configurations
- Initial list of possible vulnerabilities is generated

Example:

A scanner like Nessus checks a web server and finds:

- Open port 80 (HTTP)
- Outdated Apache version



Vulnerability analysis

Vulnerability analysis in cybersecurity includes various assessments that focus on different aspects of an organization's digital environment.

Example:

The scan reports a vulnerability in Apache, but after analysis:

- The version is actually patched false positive removed
- Only real issues are kept



Risk assessment

Assessment is the process of **evaluating and prioritizing vulnerabilities based on their severity and potential impact**. It involves security analysts assigning a rank or severity score to each vulnerability, based on such factors as:

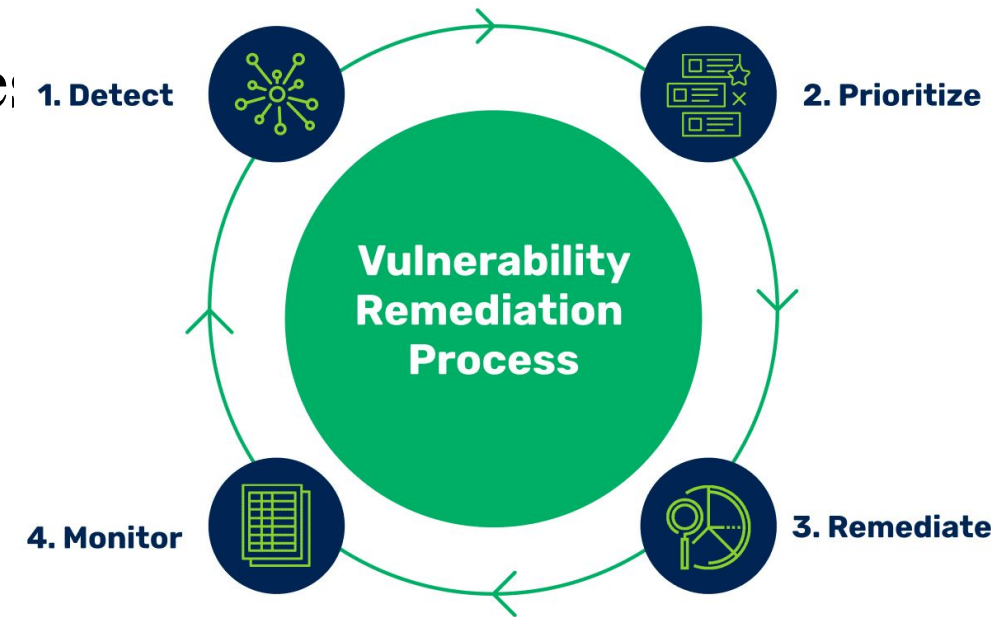
1. Which systems are affected.
2. What data is at risk.
3. Which business functions are at risk.
4. Ease of attack or compromise.
5. Severity of an attack.



Remediation

Remediation is the process **of fixing or mitigating identified vulnerabilities**. Specific remediation steps might include:

- ❖ Introduction of new security procedures, measures or tools.
- ❖ The updating of operational or configuration changes.
- ❖ Development and implementation of a vulnerability patch.



Why is Vulnerability Assessment Important?



Penetration testing

Penetration Testing is a security testing method where ethical hackers simulate real-world attacks **to find and exploit vulnerabilities in a system, network, or application.**



Types of testing

Black box testing

The tester has no knowledge of the system.



White Box Testing

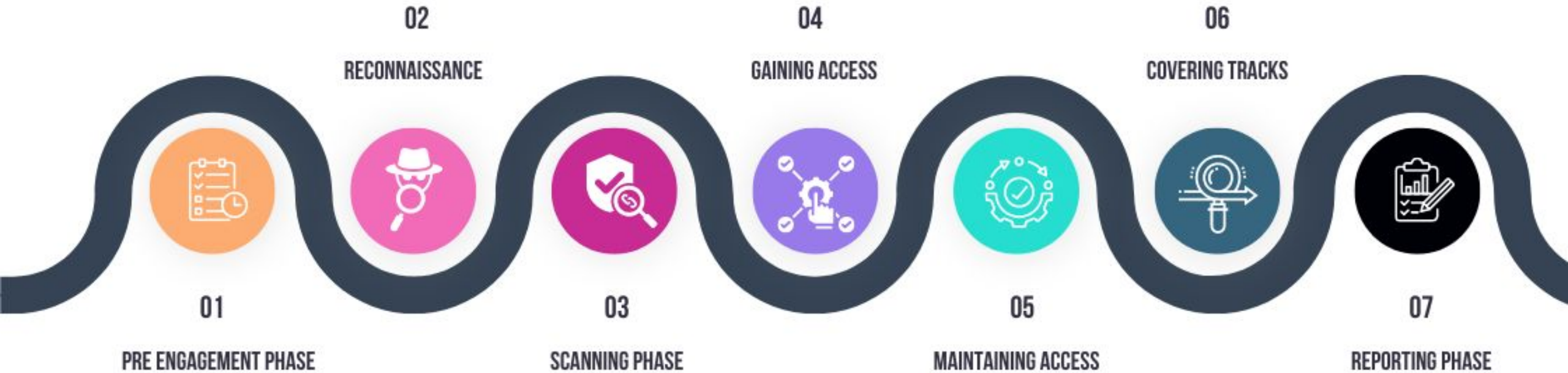
The tester has full knowledge of the system.



Gray Box Testing

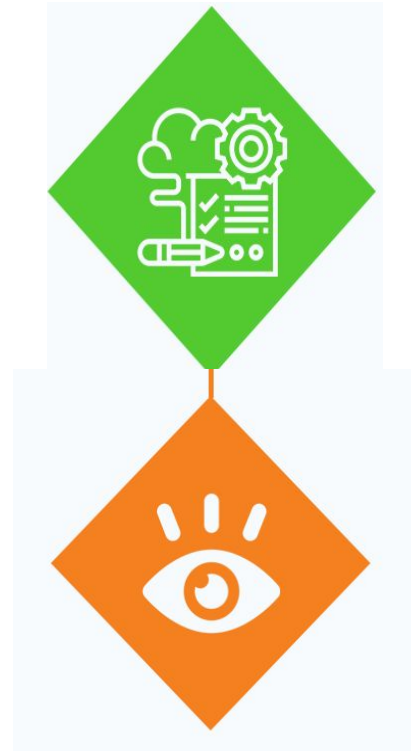
The tester has partial or limited knowledge of the system.

Penetration testing stages



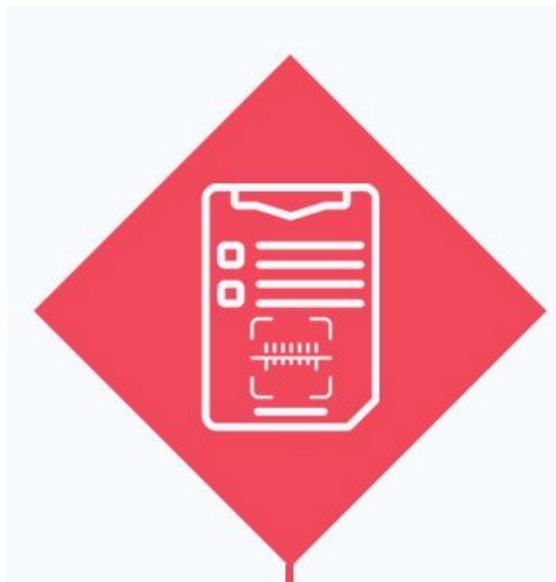
1. Planning and reconnaissance

- Defining the scope and goals of a test, including the systems to be addressed and the testing methods to be used.
- Gathering intelligence (e.g., network and domain names, mail server) to better understand how a target works and its potential vulnerabilities.



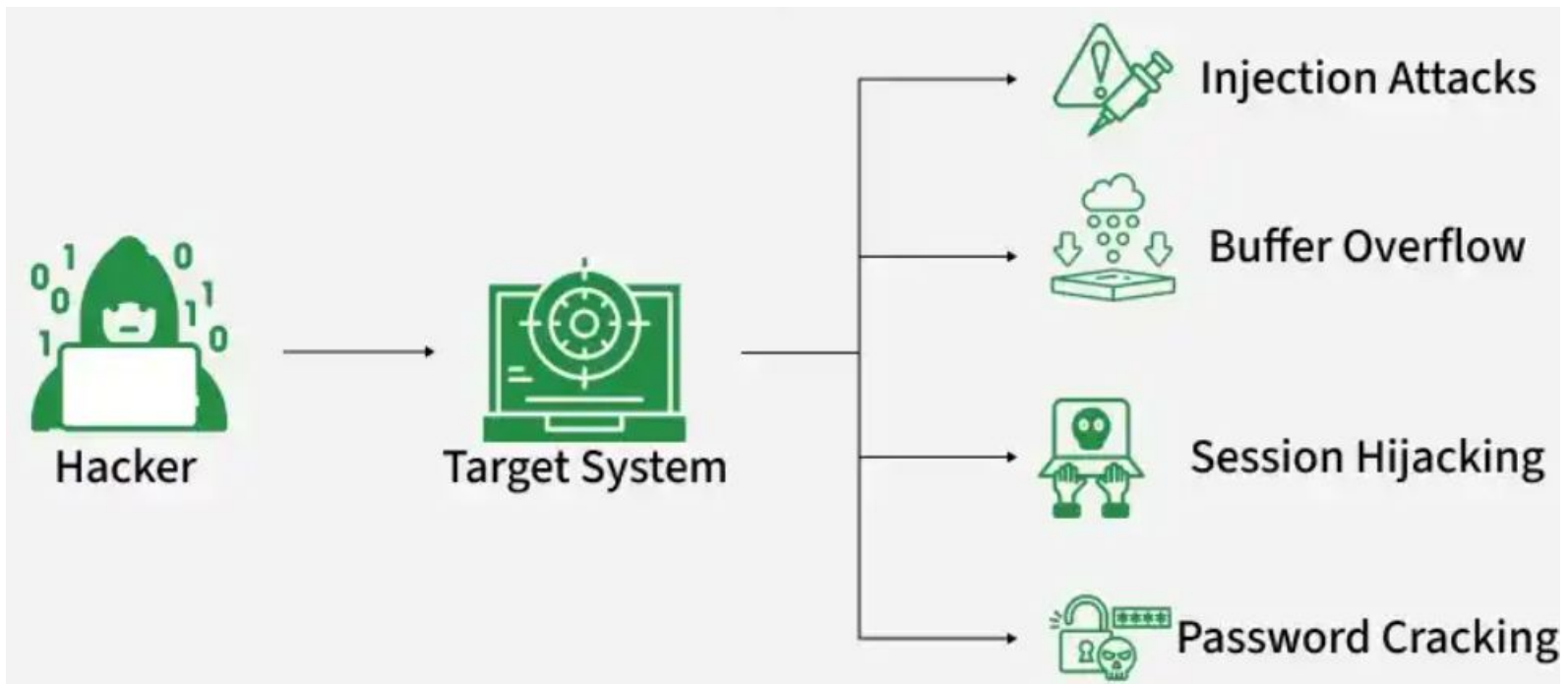
2. Scanning

- **Static analysis** – Inspecting an application's code to estimate the way it behaves while running. These tools can scan the entirety of the code in a single pass.
- **Dynamic analysis** – Inspecting an application's code in a running state. This is a more practical way of scanning, as it provides a real-time view into an application's performance.



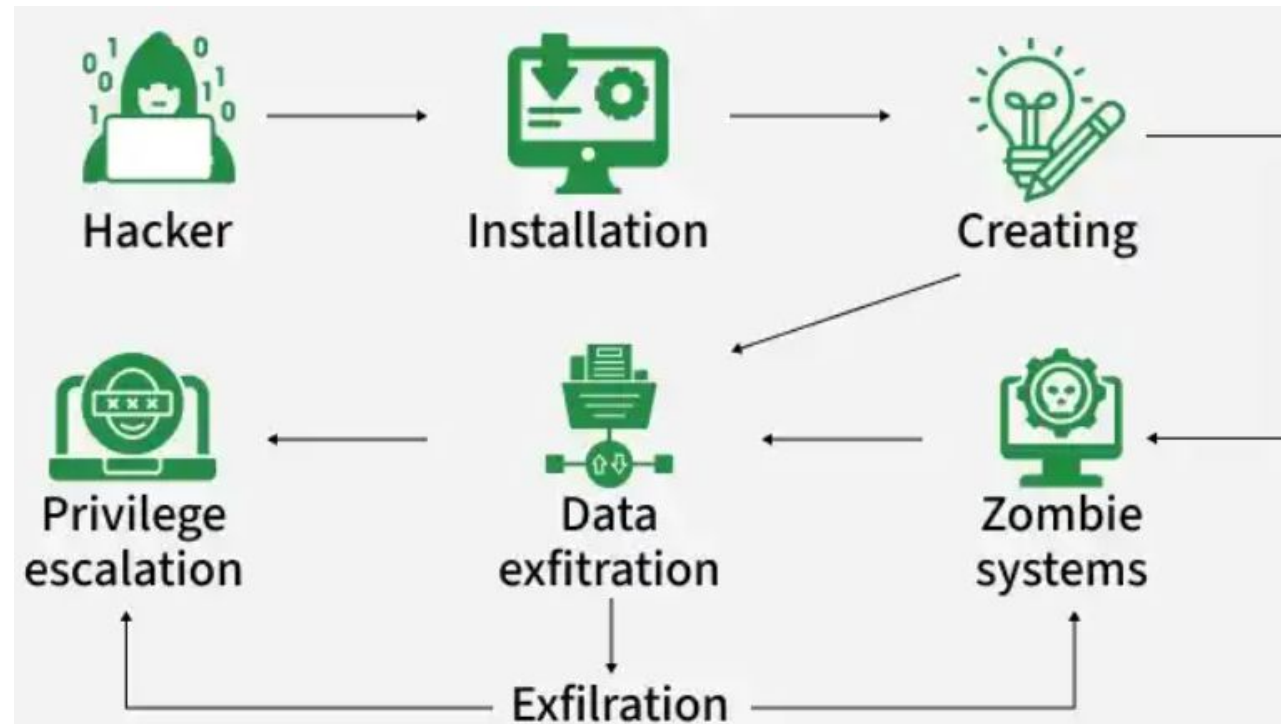
3. Gaining Access

- ❖ This stage uses web application attacks, such as cross-site scripting, SQL injection and backdoors, **to uncover a target's vulnerabilities**.
- ❖ Testers then try and exploit these vulnerabilities, typically by escalating privileges, stealing data, intercepting traffic, etc., to understand the damage they can cause.



4. Maintaining access

Maintaining Access is the phase where the ethical hacker evaluates how long an attacker could remain inside a compromised system. The goal is to assess the potential impact of the attack and understand the level of control an attacker could achieve.



5. Analysis & Reporting

Analyze all findings from the penetration test

□ Document:

- Exploited vulnerabilities
- Accessed sensitive data
- Duration of undetected access

□ Assign risk levels (Critical, High, Medium, Low)

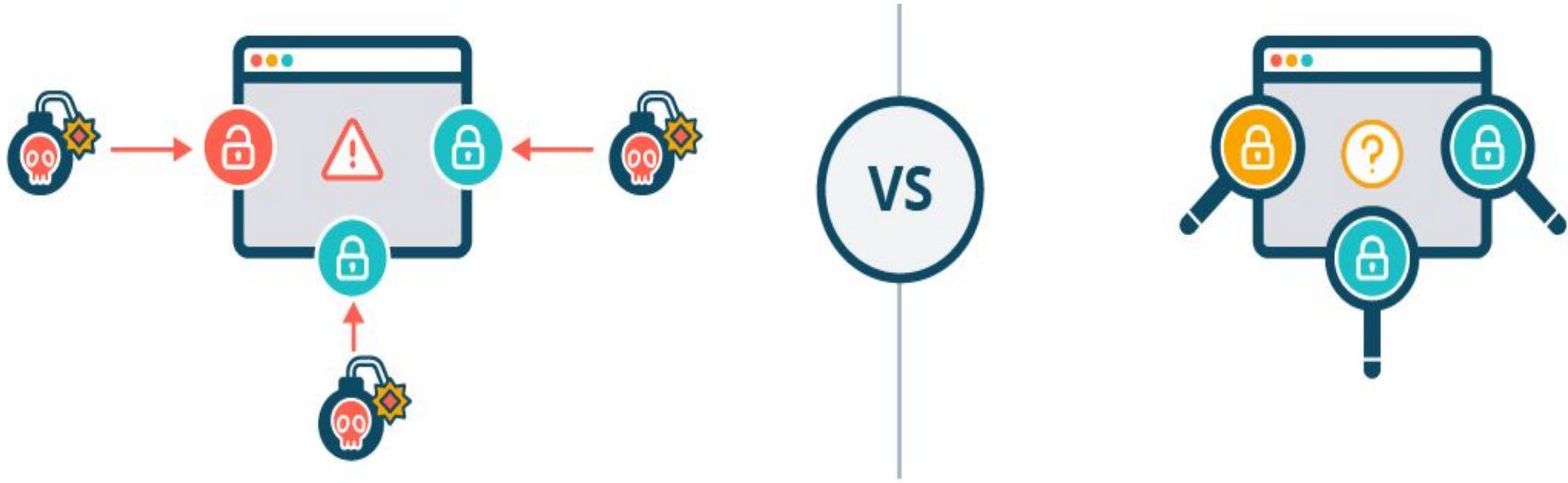
□ Provide remediation recommendations

□ Help improve security controls (e.g., WAF configuration)

Goal: Fix vulnerabilities and strengthen overall security posture



Penetration Testing **vs** Vulnerability assessments



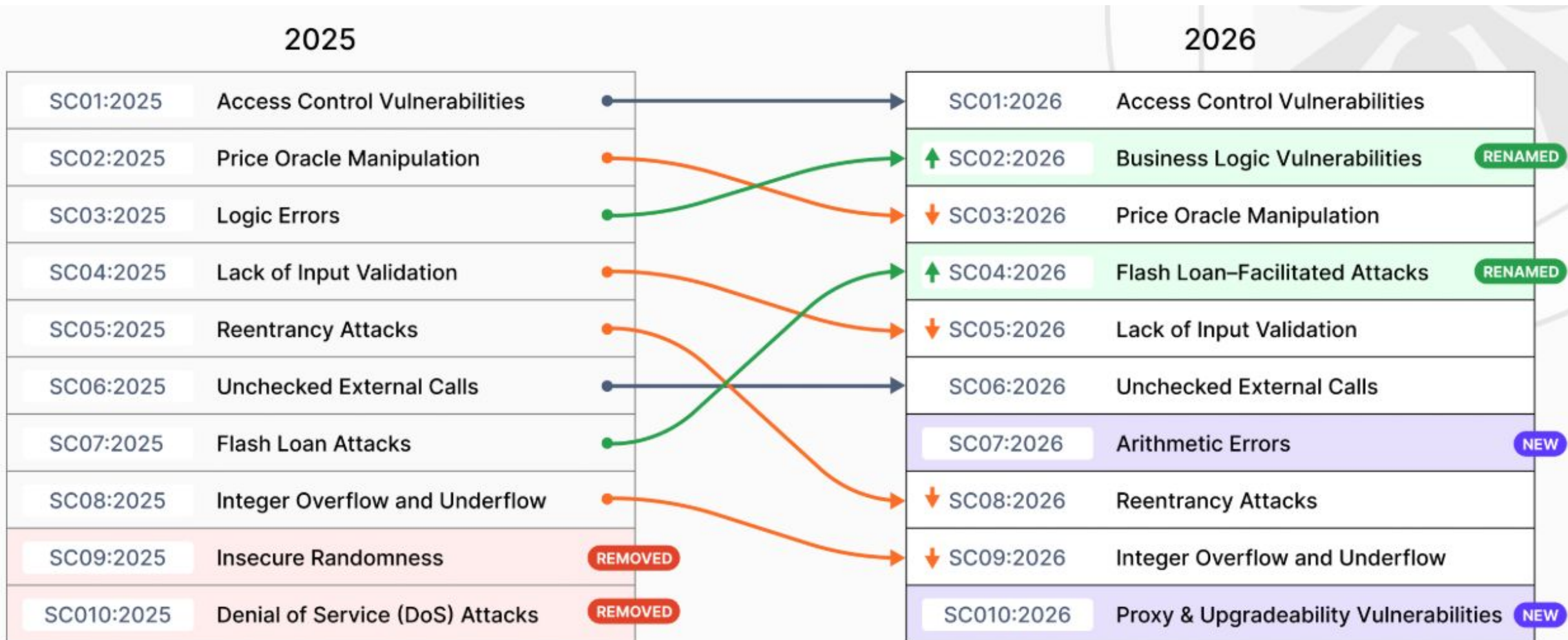
Penetration Testing **vs** Vulnerability Assessments

<i>Features</i>	<i>Vulnerability Assessment</i>	<i>Penetration Testing</i>
<i>Affordability</i>		
<i>Continuous Monitoring</i>		
<i>Expert Remediation</i>		
<i>Frequency</i>	<i>Daily</i>	<i>Annually/ Quarterly</i>
<i>Business Logic Vulnerability Detection</i>		

Penetration Testing **vs** Vulnerability Assessments

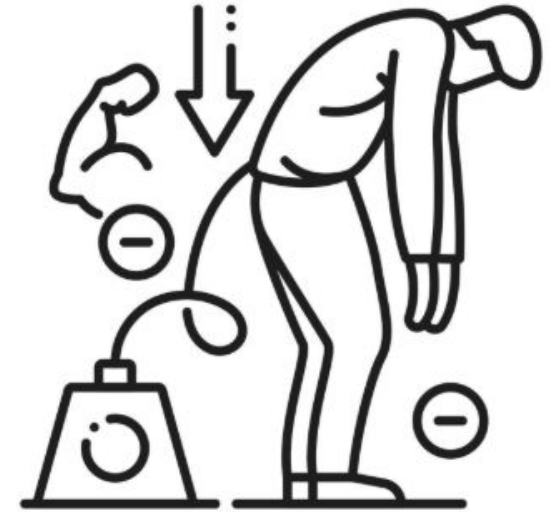
SN	Penetration Testing	Vulnerability Assessments
1.	This is meant for critical real-time systems.	This is meant for non-critical systems.
2.	This is ideal for physical environments and network architecture.	This is ideal for lab environments.
3.	It is non-intrusive, documentation and environmental review and analysis.	Comprehensive analysis and through review of the target system and its environment.
4.	It cleans up the system and gives final report.	It attempt to mitigate or eliminate the potential vulnerabilities of valuable resources.
5.	It gathers targeted information and/or inspect the system.	It allocates quantifiable value and significance to the available resources.
6.	It determines the scope of an attack.	It makes a directory of assets and resources in a given system.
7.	It only identifies the exploitable security vulnerabilities.	It identifies, categorizes, and quantifies security vulnerabilities.

OWASP top 10 vulnerabilities 2026



Weaknesses of Vulnerabilities Assessment

1. Have high false positive rate.
2. Easily detect by Intrusion Detection System firewall.
3. Cause a denial of services by generating bulk of packets.
4. Often fail to notice latest vulnerabilities.



Vulnerability assessment tools

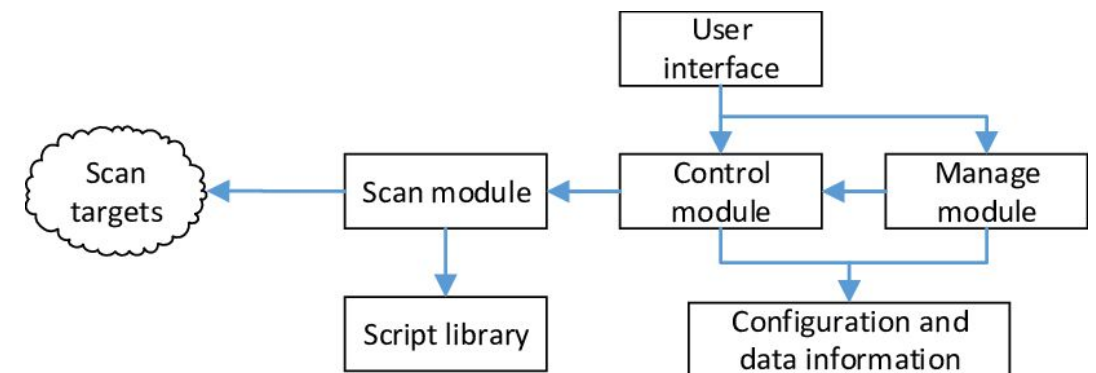
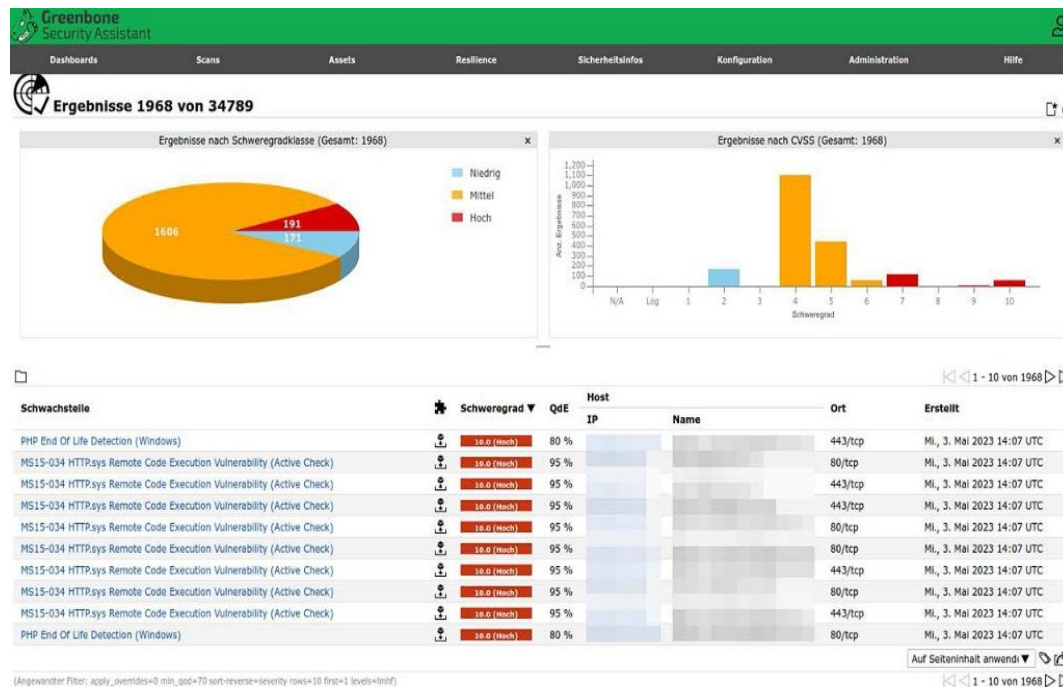


Tools for Vulnerability Assessment

OpenVAS



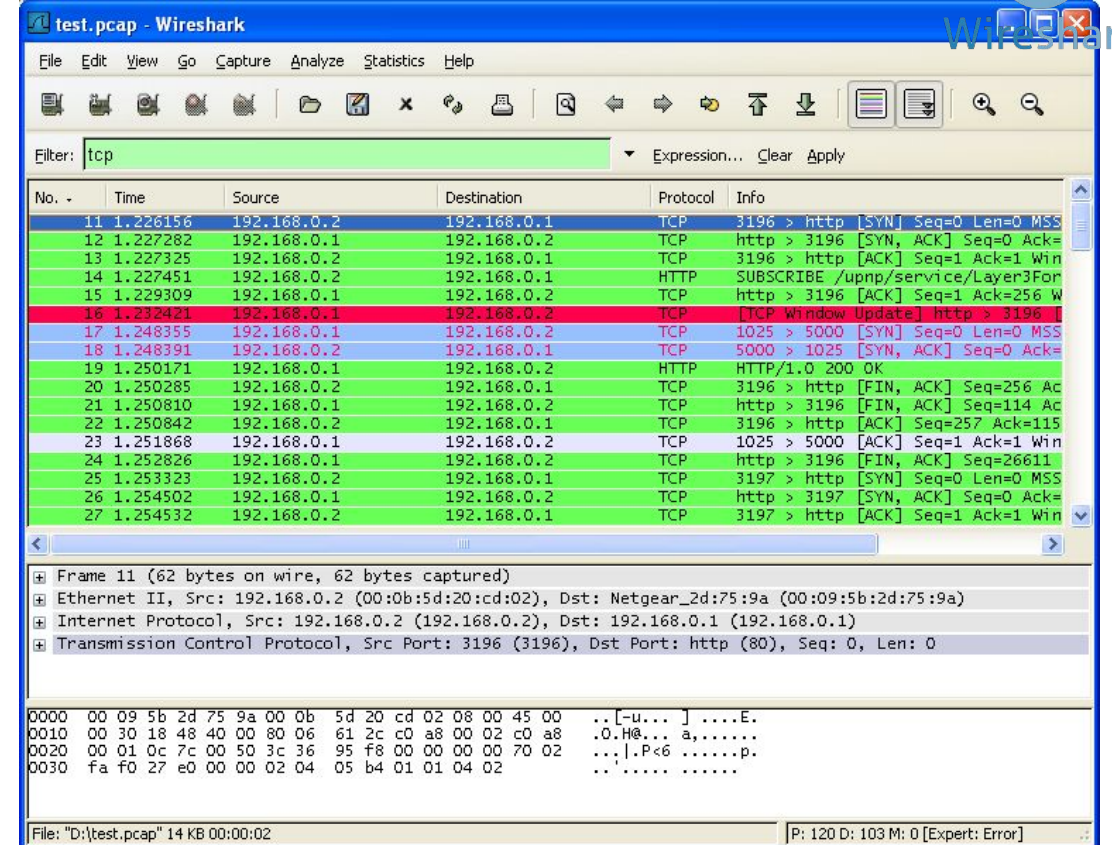
- The scan engine of OpenVAS is updated with the Network Vulnerability Tests on a regular basis.
- OpenVAS scanner is a complete vulnerability assessment tool that is used to spot issues related to security in the servers and other devices of the network.



Tools for Vulnerability Assessment

Wireshark

- Wireshark has a special feature like it captures the issues online and performs the analysis offline.
- Wireshark has the capability of deeply inspecting many protocols with further more added all the time.



Tools for Vulnerability Assessment

Nmap

- Nmap (Network Mapper) is a free and an open source security scanner used to determine hosts and services on a network by structuring the map of the computer network.



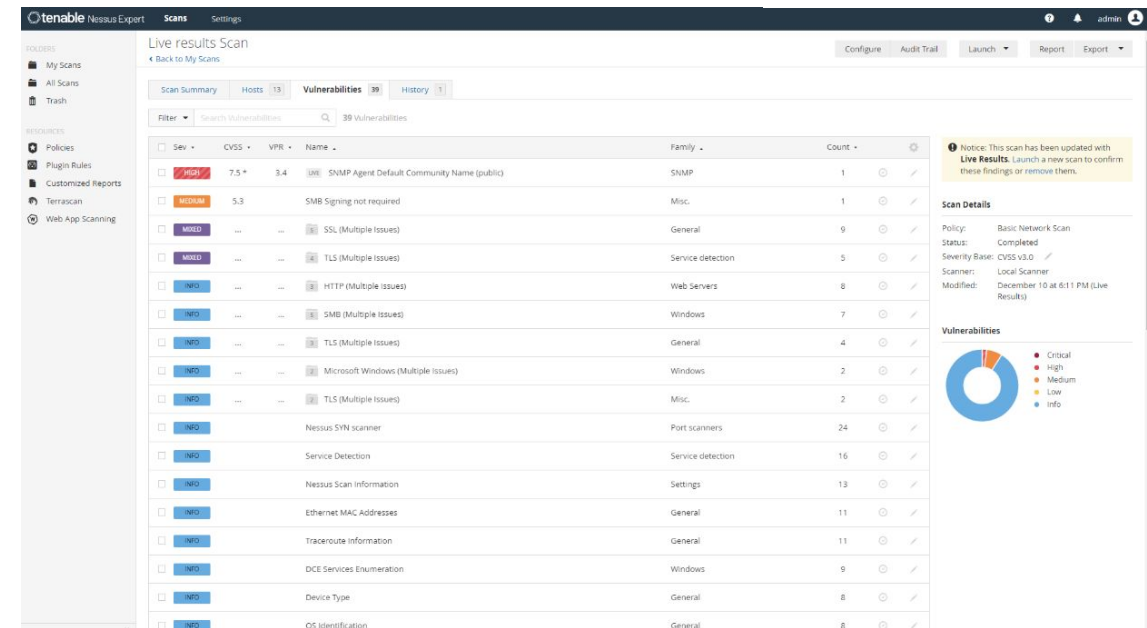
```
(kali㉿kali)-[~]  
$ nmap -A usedvehicle.us  
  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 16:09 +06  
Nmap scan report for usedvehicle.us (159.198.64.27)  
Host is up (0.23s latency).  
Not shown: 987 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
20/tcp    closed ftp-data  
21/tcp    open  ftp      Pure-FTPd  
| ssl-cert: Subject: commonName=ipv6.server1.usedvehicle.us  
| Subject Alternative Name: DNS:ipv6.server1.usedvehicle.us, DN  
S:mail.server1.usedvehicle.us, DNS:server1.usedvehicle.us, DNS:  
www.server1.usedvehicle.us  
| Not valid before: 2026-03-09T03:42:27  
|_Not valid after: 2026-06-07T03:42:26  
|_ssl-date: TLS randomness does not represent time  
22/tcp    open  ssh      OpenSSH 8.0 (protocol 2.0)  
| ssh-hostkey:  
| 2048 10:41:43:11:7a:32:e3:19:c3:7c:e8:3e:7e:39:3f:04 (RSA)  
| 256 5a:f5:a3:6f:14:05:25:96:b7:a3:e5:ef:ca:90:b4:5d (ECDSA)  
|_ 256 d8:25:7a:98:d1:65:78:9c:2a:6c:dc:72:fd:49:b6:d8 (ED25519)
```

Tools for Vulnerability Assessment



Nessus

- One of the most popular vulnerability scanners.
- Detects vulnerabilities, misconfigurations, and missing patches.
- Provides detailed reports with severity levels.



Tools for Vulnerability Assessment

Nikto

- Web server vulnerability scanner.
- Detects outdated software, dangerous files, and misconfigurations.
- Open-source and easy to use.



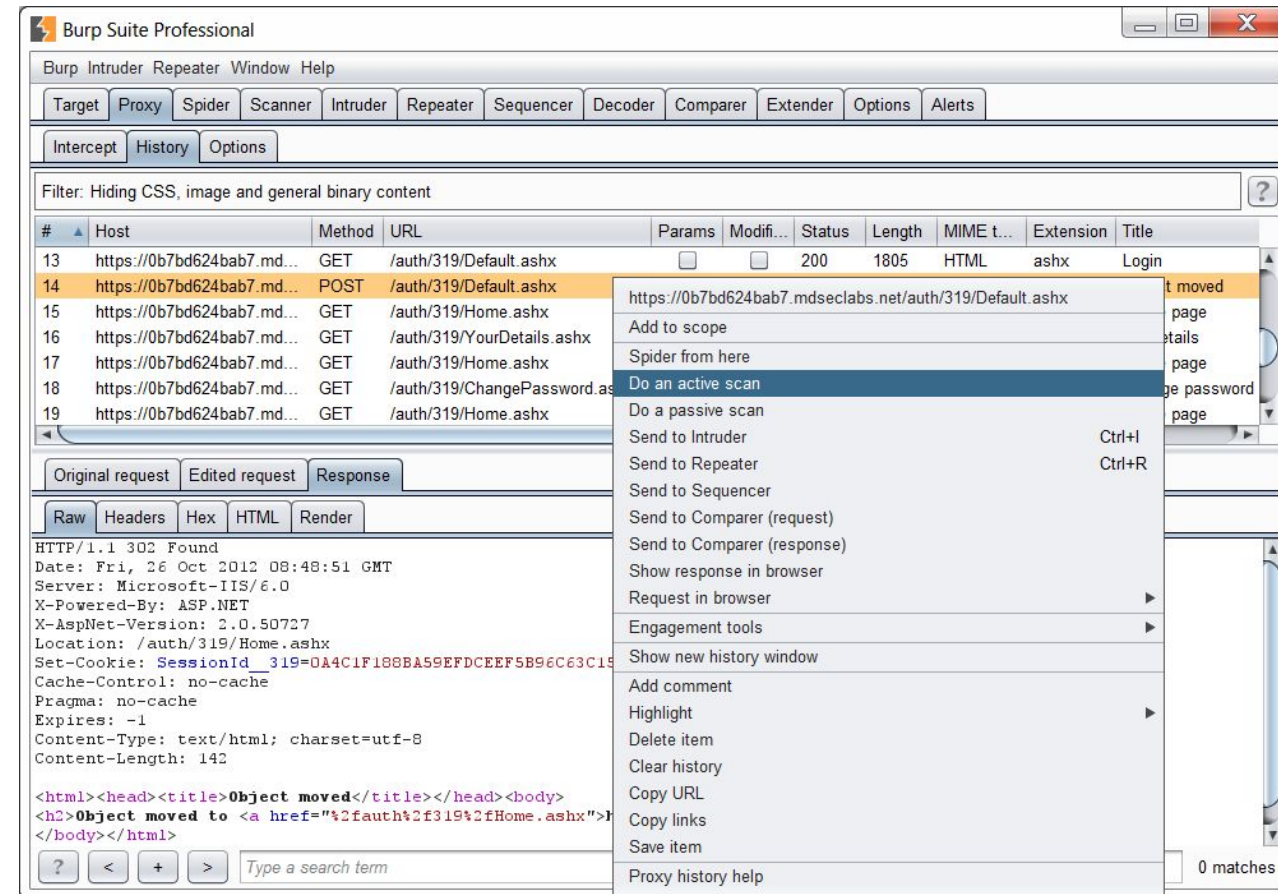
```
(kali㉿kali)-[~]
$ nikto -h usedvehicle.us
- Nikto v2.6.0

-----
+ Your Nikto installation is out of date.
+ Target IP:      159.198.64.27
+ Target Hostname: usedvehicle.us
+ Target Port:    80
+ Platform:      Unknown
+ Start Time:     2026-04-19 16:24:40 (GMT6)
-----
+ Server: Apache
+ No CGI Directories found (use '-C all' to force check all possible dirs). C
GI tests skipped.
+ [013587] /: Suggested security header missing: referrer-policy. See: https:
//developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: htt
ps://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See
: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See:
```


Tools for Vulnerability Assessment

Burp Suite

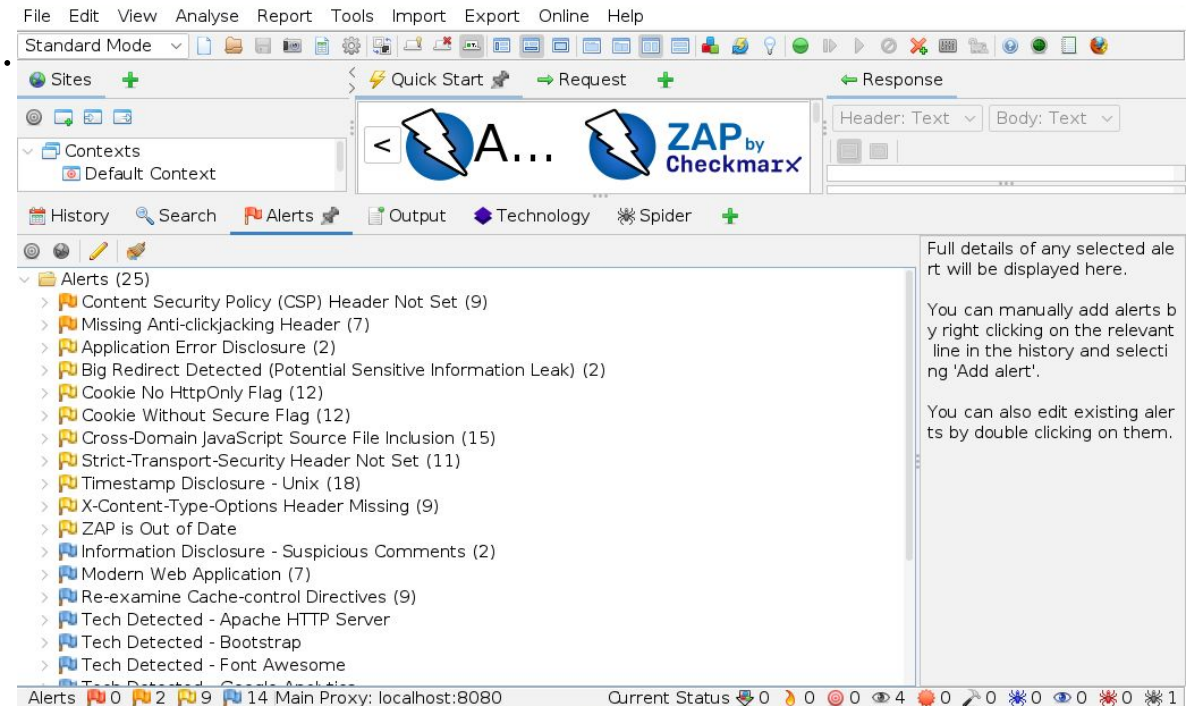
- Used for web application security testing.
- Identifies vulnerabilities like SQL injection and XSS.
- Includes proxy, scanner, and repeater tools.



Tools for Vulnerability Assessment

OWASP ZAP (Zed Attack Proxy)

- Open-source web application security testing tool.
- Developed by OWASP (Open Web Application Security Project).
- Used to find vulnerabilities in web applications.



Different Types of Vulnerabilities

- Missing data encryption
- OS command injection
- SQL injection
- Buffer overflow
- Missing authentication for critical function
- Missing authorization
- Unrestricted upload of dangerous file types
- Reliance on untrusted inputs in a security decision
- Cross-site scripting and forgery
- Download of codes without integrity checks
- Use of broken algorithms



Different Types of Vulnerabilities

- URL redirection to untrusted sites
- Path traversal
- Weak passwords
- Software that is already infected with virus
- Denial-of-service (DoS) and distributed denial-of-service (DDoS) attacks
- Man-in-the-middle (MitM) attack
- Phishing and spear phishing attacks

Different Types of Vulnerabilities

- Drive-by attack
- Password attack
- SQL injection attack
- Cross-site scripting (XSS) attack
- Eavesdropping attack
- Birthday attack
- Malware attack

Benefits of Penetration Testing

- Test network or system using the tools and techniques that attackers use.
- Demonstrate at what depth vulnerabilities can be exploited.
- Validate vulnerabilities.
- Can provide the realism and evidence needed to address security issue.



Weaknesses of Penetration Testing

- Labor intensive, require great expertise.
- Dangerous when conducted by inexperienced tester.
- Revel source code to third party.
- Expensive.
- Some tools and methods may be banned by agency regulation.
- Conducted in limited time period.
- If a service is not tested then there will be no information about its security or insecurity.

How VAPT Conduct

- Cyber Security Research Lab
- Computer Emergency Readiness Team (CERT)
- Internal & External
- Consultant
- BGD eGov CERT

Why?

- ICT Security Policy
- Avoid network downtime due to breach.
- CIA Triad
- Enhance effectiveness of an overall security life cycle.
- Provide a strong basis for helping to determine appropriate security budgets.

Thank you